Case Study:- 2

SECURING THE UNIVERSITY EXAMINATION SYSTEM:-

A university uses an Operating System based examination management System to store records, examination marks, faculty details and question paper. the System has three main user group Student, Faculty and Administrators Student should be able to view only their own marks and download permitted learning material. faculty members need to view student record and enter or modify marks Administrators manage user account permission and System configuration.

The university has assigned permission throught roles but an audit review identifies the yollowing events:

i. At 10:00 the account Student07 has three failed login attempts
ii. At 10:03 Student07 succesfully log in
iii. At 10:04 Student07 attempt to open exam marks xlsx, which contain marks for an entier class
iv. At 10:05 the System record an attempted modification of exam mark by student07
v. At 10:15 faculty02 modifies mark in Exam marks xlsx and saves the file successfully

→ At 10:20 an administration discovers that a yacator faculty member account discover is still active

→ The audit log is stored on the same severs and users with broad permission may be able to modify or delet it

The university want to protect conyidentiality integrity and availability prevent unauthored acces maintain accountability and investigate suspicious activity You are asked to recommend appropriate opprating System access control security - administration and auditing measures

Question

- Identify the main security problem in the acase study

List at least four risks or weaknesses indicated by the Scenarion

→ i weak or improper access permission

ii fomer faculty account may still be active

iii Mark of the entired were exposed causing conyidentiality issuse

iv Three yailed login attempt were recorded which may indicate an attempt to accress an account

Q2 Explain the difference between authentication and authorization using Student07 as an example. (4 mark)

→ Authentication means verifying the identity of user. In this case, the System record three failed login attempt by Student07 at 10:00 followed by successful login at 10:03

Authorization mean checking what action a user is permitted to peryorm. Student07 may access permitted learning materials and their own mark but should not be allowed to modify ExamMarks.xlsx.

Thus authentication verifies the user's identity, while authorization checks their access permissions

Q3 Recommend an access-control policy for student, faculty and Administrator

→ The university should use Role-Based Access control (RBAC) in which permission are assigned according to the user's role

i Student :- can view their own mark and download permitted learning materials
Faculty :- Can view Student records and enter or modify mark for their assigned subject
Administrators :- Can manage user account permmission and System configuration

RBAC is suitable because it makes access manggement easier and prevent users from accessing inyormation or peryorming

PAGE No.
DATE / /

Q4 Prepare a suitable Access control list (ACL) for ExamMarks.xlsx

→

User Group	Read	write	Delete
Student	yes	NO	NO
Faculty	yes	Yes	Yes
Administrator	Yes	yes	Yes

Q5. Explain how the Principle of least Privilege should be applied

→ The principle of least Privilege means giving users only the permission they need to perform their work.
Student :- Should only view their own mark and permitted learning material. write and delete permission for the mark file must be removed
Faculty :- Should view and modify mark for their assigned subject but should not delete the entire marks file
Administrators :- Should manage account permission and system setting without automatically receiving unnecessary file-editing or deletion permission.
This principle reduces accidental change, misuse of account and unauthorized access to confidential information.

Q6 Interpret the audit event from 10:00 to 10:05 what should the security team do next?

→ The sequence of event is suspicious because student07 makes three failed login attempt at 10:00 successfully login in at 10:03 attempt to open Exam Mark.xlsx at 10:04 and attempt to modify the file at 10:05
This could indicate an attempt to access or change confidential mark without permission However, the event do not prove that an attack occured

The security team should:

- Check whether student 07 was authorized to access the marks files
- Review the login record and verify whether the succesful login was legitimate
- Investigate whether any mark were actually changed
- Preserve the audit logs and check for other suspicious activities
- Block unauthorized access and take appropriate action if missuse is conyirmed.
- The yaculty memeber successyul mark updata at 10:15 should also be checked aganist their assigned permission the yormer yaculty member active account should be investigated seperately.

Q7 Identiyy at least yive event that should be recorded in the audit logs

The System should record:-

- Successyul and failed login attempts
- Attempts to open or access yiles
- Changes to student mark
- Creation modiyication or deletion of user accounts
- Change to roles and access permission
- Administrative and system conyiguration changes

These records help the university identify suspicious activities and investigate security incidents.

Q8 Explain why audit logs must be protected and recommend two ways to protect them.

→ Audit logs must be protected because they provide evidence of user activities and security incident. If someone modifies or deletes the logs the university may lose important evidence during an investigation

Two ways to protect them are:

- Restrict access :- only authorized security personal should be able to manage the logs
- Use tamper-resistant storage :- store logs on a separate protected server and use mechanisms that detect unauthorized changes

These measure help maintain the accuracy and reliability of audit records

Q9 what action should be taken regarding the former faculty active account?

→ The university should immediately disable the former faculty member's account and revoke their access to university system

It should also terminate active sessions, review the account previous activities and remove any unnecessary permission.

This is important because former faculty members no longer require access to university resources. Disabling inactive account reduces the risk of unauthorized access and data misuse.

Q10 Suggest a practical incident response and corrective action plan for the university

→ Investigate: Review the audit logs, verify student activities and check whether any mark were changed without authorization.
Review access:- Disable the former faculty memeber account and examine the permission of student faculty and administrator
Improve Security:- Apply RBAC and the principle of least privilege, enforce strong password and enable multi-factor authentication where possible
Monitor regularly:- Protect audit logs, review suspicious activities conduct periodic acress review and verify that corrective measure are effective

- Those steps will help protect confidential student records prevent unauthorized changes and improve the overall security of the university's operating system.